Continuous Assessment – 1 (Part-2)

Phishing and Vishing Simulation

Team Members:

1) Karnishwar R – 20086868

2) Anandha Krishnan S – 20055947

3) Sanu Mathew – 20075856

Module Title and Code - ORGANISATIONAL AND SOCIETAL CYBERSECURITY (B9CY106)

Module Instructor - Alexander Victor

Submission date - 18-02-2026

Total words - 2168

TABLE OF CONTENTS:

S.NO	TOPIC	PAGE NO.
1	Task 1 - Phishing Email Simulation Objective	3
2	Task 1 - Environment Setup	4
3	Task 1 - Phishing Email Design	4
4	Task 1 - Technical Implementation	6
5	Task 1 - File Payload Simulation	8
6	Task 1 - Campaign Metrics and Analysis	8
6.1	Task 1 - Calculations	9
7	Task 2 - Vishing Simulation Objective	9
8	Task 2 - Tools used	10
9	Task 2 - Attack Design	10
10	Task 2 - Transcript of call	10
11	Task 2 – Observations from the call	13
12	Task 2 - Psychological Principles Exploited	13
13	Conclusion	14
14	References	15

Task 1 – Phishing Email Simulation:

1. Objective:

The objective of this task was to design and execute a targeted phishing email campaign in a controlled lab environment. The purpose of this simulation is to help us understand how attackers use phishing mails to lure people, how people respond to them and how are the user credentials being extracted using specific tools. The attack was conducted ethically using only test email accounts created for this assignment. No real people or organizations were targeted.

Phishing is one of the most common forms of social engineering attacks, which allows attackers to easily get sensitive details by exploiting human psychology rather than exploiting technical vulnerabilities.

The **Social-Engineering Toolkit** was used to simulate both the email distribution and credential harvesting parts involved in the attack.

```
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether ae:07:20:c9:88:78 brd ff:ff:ff:ff:ff:ff
    inet 192.168.64.8/24 brd 192.168.64.255 scope global dynamic noprefixrout
e eth0
       valid_lft 3502sec preferred_lft 3502sec
    inet6 fd38:e520:ad90:2d1f:7f5c:3932:1138:35c5/64 scope global dynamic nop
refixroute
       valid_lft 2591908sec preferred_lft 604708sec
    inet6 fe80::f66d:6f60:150a:a05b/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

IMAGE 1 – Kali IP

2. Environment Setup:

This simulation was performed using Kali Linux VM acting as the attacking system. The fake website that was used as phishing lure was set up on Kali VM and can only be accessed using the VM's internal IP address. The victim was simulated using test email accounts created for this attack and accessed through a web browser in the host MacOS. The phishing link sent through email, only involved the private IP of the Linux VM, ensuring that it is not it is not accessible in a public environment.

As shown in [IMAGE 1], the default internet route was removed from VM to prevent external access.

The below images shows failure of access to google public DNS server(8.8.8.8) ensuring the attack was fully isolated.

```
┌──(kali㉿kali)-[~]
└─$ sudo ip route del default
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ ip route
192.168.64.0/24 dev eth0 proto kernel scope link src 192.168.64.8 metric 100

┌──(kali㉿kali)-[~]
└─$ ping 8.8.8.8
ping: connect: Network is unreachable
```

IMAGE 2 – Public Internet Access Blocked

3. Phishing Email Design:

The phishing scenario was based on the theme of **"Final Semester Examination Results".** This theme was selected because students often react strongly to academic results making them to most likely respond quickly.

[IMAGE 3] Shows the subject and the body of the email received by the victim. The email was structured to resemble a legitimate academic notification and the time constraint mentioned in the mail creates a sense of urgency among the students leading them to either click the link and login or download the malicious file from the download link embedded in the mail. Social

engineering attacks are successful because they manipulate people psychology rather than exploiting technical flaws.

IMAGE 3 – Email Received on Victims Mail

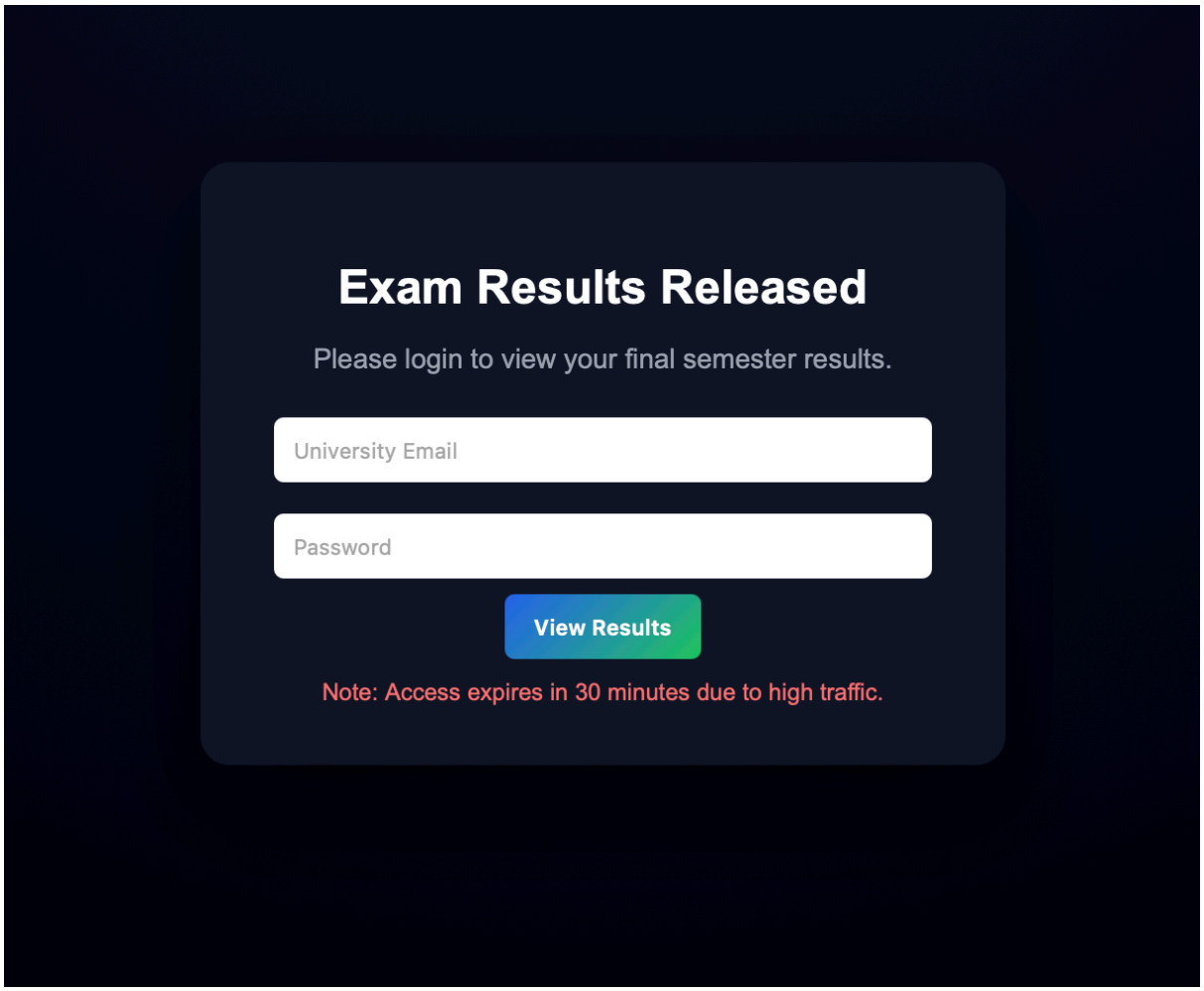

IMAGE 4 – Fake Phishing Site Login page

4. Technical Implementation:

The phishing attack was performed using the **Social-Engineering Toolkit.** The following modules were used to perform the attack:

1) Mass Mailer Attack – Used for sending the phishing mails.

2) Credential harvester – Used to capture the login details when the victim entered their credentials in the phishing site.

The phishing website was imported into **SET** using custom Import feature which allows user created webpages to be imported from the local system and be deployed as a lure. When the victim clicked the link and submitted the credential, the browser submitted the information via an **HTTP POST** request. The **Credential Harvester** tool running in the background intercepts this POST data and displays the captured user credentials in the Linux terminal.

After submitting the credentials the users were redirected to the page where they can download the results as a file, making it appear as the results are in the file. This was done to reduce suspicion and make the website appear legitimate.

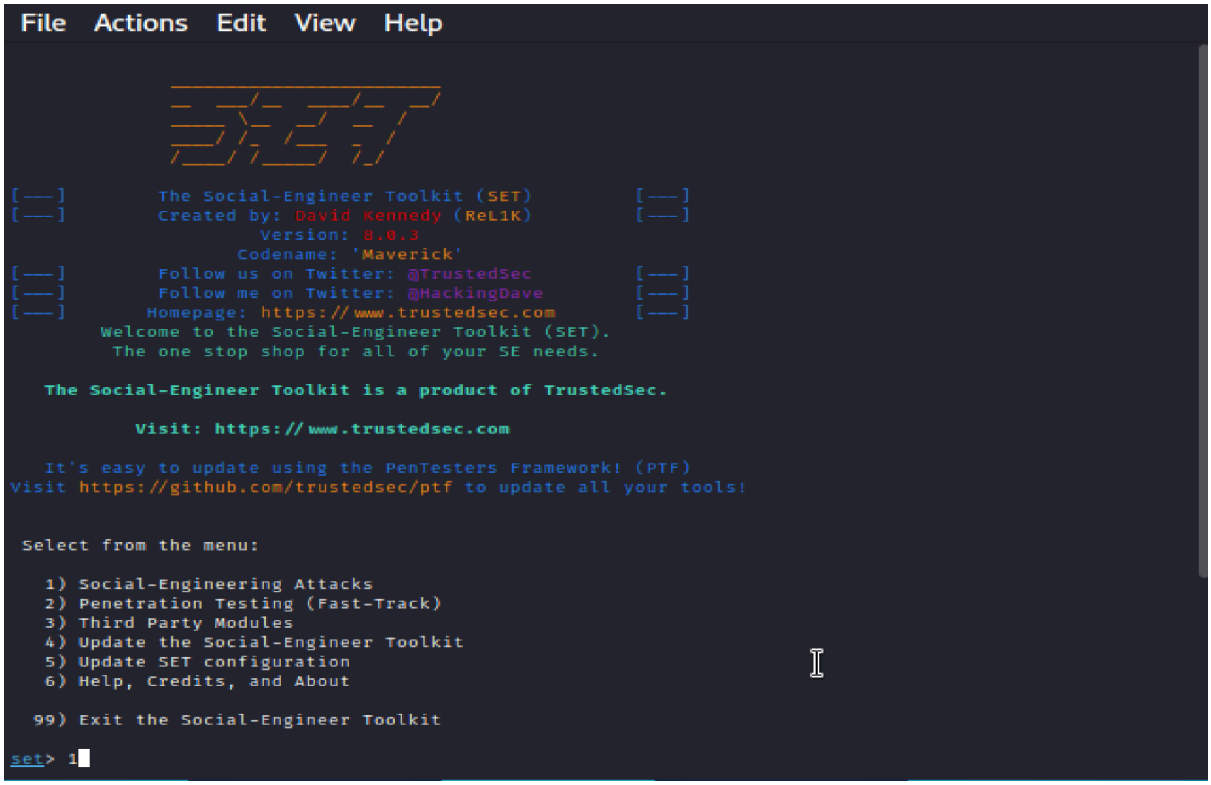

IMAGE 5 – SE TOOLKIT.

```
2. Copy the entire folder

Enter choice [1/2]: 2
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported:http://192.168.64.8/loading.ht
ml

The best way to use this attack is if username and password form fields are a
vailable. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.64.1 - - [15/Feb/2026 11:33:39] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=899509
POSSIBLE PASSWORD FIELD FOUND: password=Asdfght
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.


192.168.64.1 - - [15/Feb/2026 11:34:02] "POST / HTTP/1.1" 302 -
192.168.64.1 - - [15/Feb/2026 11:34:02] "GET /loading.html HTTP/1.1" 200 -
192.168.64.1 - - [15/Feb/2026 11:34:14] "GET /loading.html HTTP/1.1" 200 -
^C
      Press <return> to continue
```

IMAGE 6 – Credential Captured

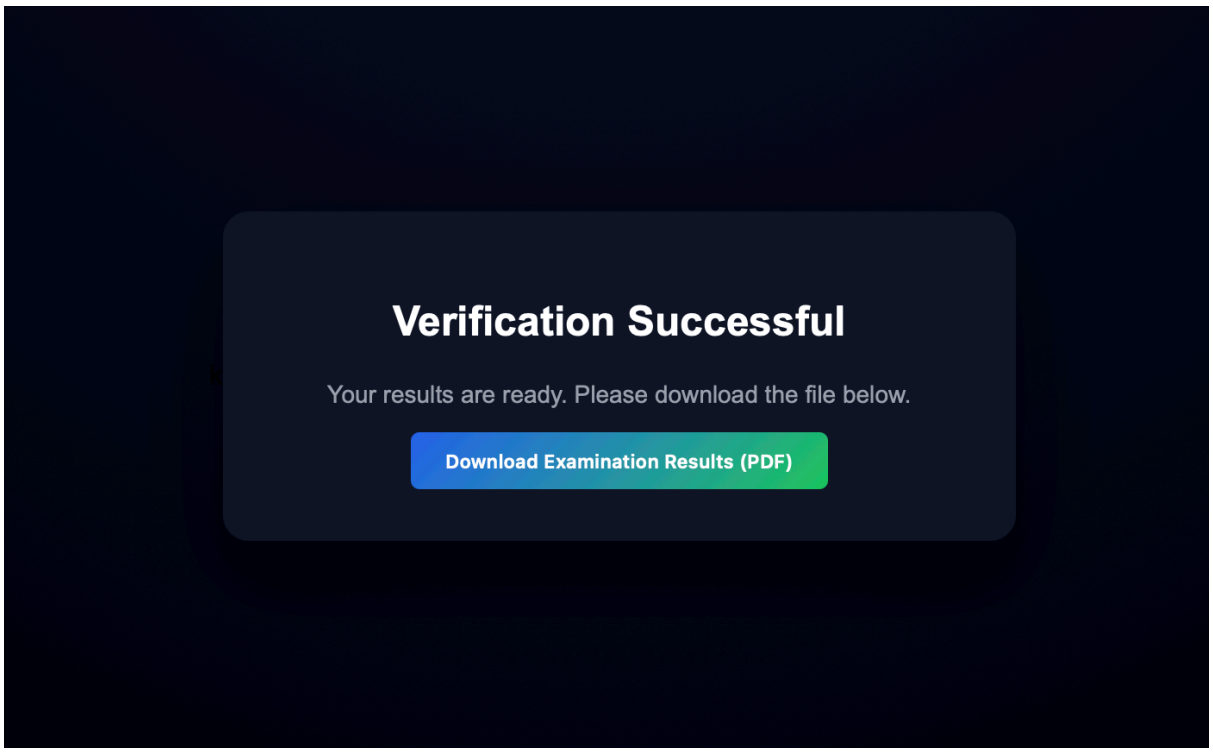

IMAGE 7– Fake Phishing Site Redirection page

5. File Payload Simulation:

In addition to link there is also a simulated file-based payload linked with a download button in the webpage. A harmless pdf file was created and added into the same directory as of the phishing page. Then the file was added into the redirection part of the webpage with a download button. When the victim clicked the download button the file was loaded into the victims machine. This was done to simulate real-life phishing attacks. The file included in the simulation did not contain any malicious data.

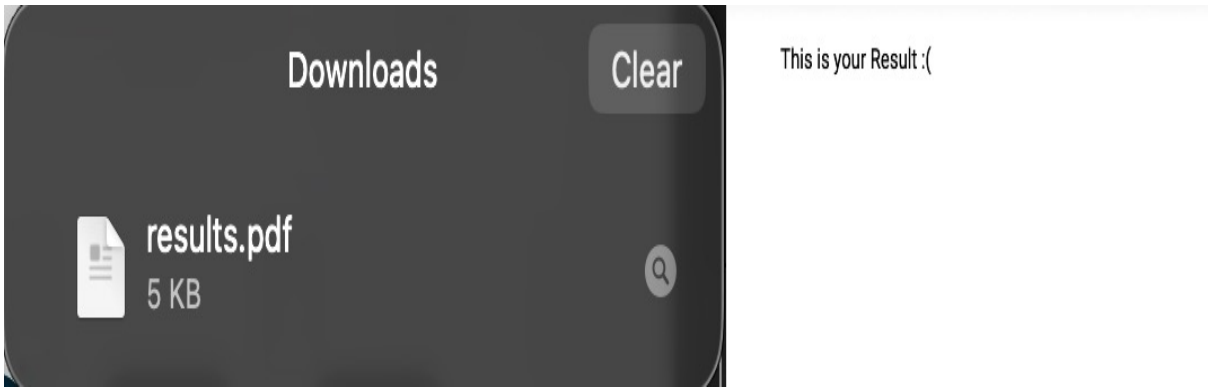

IMAGE 8 – PDF downloaded in victims system

6. Campaign Metrics and Analysis:

A total of 7 email accounts were included in the simulation, and all the emails were successfully delivered. Out of seven recipients, six people accessed the website link, resulting in a click-through rate of approximately **86%.** Out of the 6, 4 people entered their credentials making the credential submission rate approximately 51%. In addition, 3 people downloaded the malicious file.

These difference between link access, credential submission and file download provides us some information on user decision making. While most victims accessed link only few people were ready to submit their credentials. Although the email created a sense of urgency some victims hesitated to provide their personal information. The lower download of files also indicates that user trust is decreased when the risk of action increases.

Metrics	Value
Emails sent	7
Emails Delivered	7
Link clicks	6
Credentials submitted	4
File Downloads	3
Click-through rate	~ 86%
Credential submission rate	~ 57%

6.1 Calculations:

Click through rate – (6/7) x 100 = 85.7%

Credential Submission Rate = (4/7) x 100 = 57.1%

Task 2 – Vishing Simulation:

7. Objective:

The objective of this vishing simulation is to analyse how voice-based social engineering attack techniques can be used to manipulate people to provide their sensitive information. Unlike the first task, phishing email which included technical interfaces, this task only involves manipulation of people with verbal communication through a phone call. This simulation was designed to replicate a realistic conversation between the attacker and the victim, where the attacker pretends to be an IT support official from the victims university. This simulation was done in a controlled environment and only with a consenting participant.

8. Tools used:

This simulation was performed through a direct phone call between the attacker and a consenting participant acting as a victim. Call recording application was used to record and document the conversation, and **Otter.ai** tool was used to generate transcript of the call.

9. Attack Design:

The attack was designed as an follow-up for the phishing mail simulation performed in task 1, which was viewing exam results. The attacker pretended as a IT official of the victims university and claimed that there was multiple fake login attempts detected in his account following the exam results release.

The goal for the attacker was to get the following details from the victim:

1) Student ID

2) OTP

3) Account Password

The attack involved specific techniques like **Authority framing** (pretending as IT support official**), Urgency** (Account suspension if action was not taken soon), **Fear appeal** (Multiple fake login attempts).

10. Transcript of call:

Attacker:

Hi, is this Naveen kumar M

Victim:

Yes, speaking

Attacker:

Hi, Naveen. This is Karnishwar calling from the university, IT security team. I'm contacting you regarding a security alert triggered on your university portal account about 20 minutes ago. Is this a good time to speak to you?

Victim:

Yes. What happened?

Attacker:

So we, have detected multiple failed login attempts from an external IP address outside Ireland. As a part of security protocol, we are reaching out to students whose accounts may be at risk. We want to prevent temporary suspension before exam results are released.

Victim:

Oh, okay, that sounds serious.

Attacker:

Yes, it is. If we don't verify your account within the next 10 minutes, the system may automatically lock your portal access as a precaution.

Victim:

Okay, what do I need to do first?

Attacker:

Can you please confirm your student ID number for verification.

Victim:

Yeah, it's STU2042001

Attacker:

okay, thank you, Naveen, and just to confirm you're enrolled in the MSC cyber security program, right?

Victim:

Yes, you're right.

Attacker:

Perfect, I'm now sending you a six digit verification code to your registered university email. This is a part of the identity confirmation process. Please let me know when you receive it.

Victim:

Yes, I got it.

Attacker:

Great. Could you please read the code to me?

Victim:

It's 4829310.

Attacker:

thank you so much, Naveen. Let me just verify that in the system, Just give me a minute.

Victim:

Yeah.

Attacker:

Oh, okay. Naveen, looks like one flag has been cleared, but there is still one more flag in your system. And as a final step, could you please confirm your current portal password so we can verify it against the login attempt records.

Victim:

What Wait? Are you serious? I thought you could never ask for passwords.

Attacker:

Yes, Naveen, you are absolutely right, and I know your concern. However, during an active security incident, manual verification is required before automatic suspension, this request is logged internally and will not be stored after verification. So if we don't confirm this now, your portal may be temporarily locked and you will not be able to view your results.

Victim:

Okay, my password is NAVIN@123

Attacker:

Thank you so much, Naveen, that matches our records. Just give me a minute so I can clear the other flag also. Okay Naveen perfect your security flag has been cleared. Please avoid clicking unknown result links and report suspicious emails immediately.

Victim:

Okay, thank you.

Attacker:

No problem Naveen, hope you have a great day.

11. Observations from the call:

The call was performed between two consenting participants and the behavioural patterns in the interaction was analysed. At first, the victim spoke with a calm and professional tone since he was told that and IT official from his university called him. Making claims like **account had multiple fake login attempts, temporary account suspension, cannot view results,** created a sense of urgency in the victim making him provide the student id and OTP quickly. When the password was asked, the victim hesitated showing awareness in basic security. But, after providing reassurance and ensuring that the password would be deleted after fixing the issue, the victim provided the password too.

12. Psychological Principles Exploited:

The vishing simulation depended on behaviour responses that influence the decision user makes during the communication. The main psychological principles exploited during the simulation was

1) Perceived authority – Pretending to be an IT support official from the University.

2) Urgency – Account suspension if immediate action was not taken.

3) Fear – Mentioning multiple fake login attempts were done in the account.

4) Gradual Escalation – Involving the user in a normal conversation to build trust and gradually increasing the details to be provided from basic details for verification upto sensitive data.

13. Conclusion:

This project showed how social engineering attack can be made with both phishing emails and vishing calls. The phishing simulation proved that emails designed with urgency and authority can make victims click links and submit details or even download malicious files, same goes to vishing calls as well. Vishing showed how a verbal communication that creates a sense of urgency as well uses authority makes people provide sensitive details.

Overall, this simulation proved that cyberattacks not only happen due to technical weakness but also human weakness. Humans are often considered as the weakest link in cybersecurity. In this Vishing simulation the attackers exploited psychological vulnerabilities.

To prevent phishing and vishing attacks companies must adapt human-focused security practices and strengthen their technical part. MFA can be enabled, so even if the attackers gain login credentials MFA prevents them from entering the system Strong password policies also should be implemented. Email filtering systems that detected phishing mails should be implemented in systems.

Employees and students must be given training on how to identify malicious links, and malicious callers and also be advised on not sharing sensitive credentials like passwords or OTP's. Regular phishing and vishing drills should be conducted so that users can easily recognize spam mails and calls. By implementing these security measures, organizations can significantly reduce the success rate of attacks.

14. References:

1. Otter.ai, n.d. *Otter.ai*. [Online]
Available at:
https://otter.ai/u/kEgBg7pauKWY9ZOHmM2QVSeP5Vw?utm_source=copy_url
[Accessed 17 February 2026].

2. TrustedSec, n.d. *Social-Engineer Toolkit (SET)*. [Online]
Available at: https://trustedsec.com/resources/tools/the-social-engineer-toolkit-set
[Accessed February 2026].

3. UTM, n.d. *UTM virtual machine*. [Online]
Available at: https://mac.getutm.app
[Accessed February 2026].

4. Security, O., n.d. *Kali Linux*. [Online]
Available at: https://www.kali.org/docs/
[Accessed February 2026].